CENTRIX

DYNAMIC APPLICATION SECURITY TESTING

CONFIDENTIAL SECURITY REPORT

Security Assessment Report

Report ID	RPT-A23DF410
Scan ID	SCN-0B5DC0BF
Target	http://testaspnet.vulnweb.com/
Environment	Production
Scan Profile	full
Generated	2026-10-08 21:06:39Z
Duration	276s

2 Critical	**0** High	**0** Medium	**0** Low	**60** Evidence

Metric	Value
Overall Risk	Critical
Findings	3
Captured Evidence	60
Critical / High	2 / 0

This report was generated from authorised DAST scan data. Results should be validated and prioritized alongside business context before remediation deadlines are set.

Executive Summary

The assessment identified 2 critical and 0 high severity findings. These issues should be reviewed immediately because they may enable data access, account abuse, or service compromise.

Risk Breakdown

Severity	Count
Critical	2
High	0
Medium	0
Low	0
Info	1

OWASP Top 10 Coverage

Category	Status	Findings
A01: Broken Access Control	Tested - Clean	0
A02: Cryptographic Failures	Found	1
A03: Injection	Found	2
A04: Insecure Design	Not Tested	0
A05: Security Misconfiguration	Tested - Clean	0
A06: Vulnerable and Outdated Components	Tested - Clean	0
A07: Identification and Authentication Failures	Tested - Clean	0
A08: Software and Data Integrity Failures	Not Tested	0
A09: Security Logging and Monitoring Failures	Not Tested	0
A10: Server-Side Request Forgery	Tested - Clean	0

Findings Summary & Evidence Classification

ID	Severity	Class	Conf	Finding	Target	Param	Evid	Status
VLN-4D2A	Critical	Confirmed	8/10	SQL Injection	/ReadNews.aspx	id	1	validated
VLN-53EF	Critical	Confirmed	8/10	SQL Injection	/Comments.aspx	id	1	validated
VLN-AF3A	Info	Informational	0/10	Cryptographic / Transport W...	/	scheme	1	pending

Remediation Plan

Use this plan to triage findings by severity and confidence. The suggested timelines are starting points; shorten them for internet-facing, unauthenticated, or business-critical assets.

Severity	Suggested owner action	Target SLA
Critical	Stop exposure, patch or mitigate immediately, then retest.	24-48 hours
High	Assign to owning team, create fix branch, verify exploit path.	7 days
Medium	Patch in normal sprint, add regression coverage.	30 days
Low / Info	Review as hardening backlog and document acceptance if needed.	60-90 days

Prioritized Fix Queue

Priority	Finding	Severity	Owner Hint	Retest
P1	SQL Injection	Critical	Backend/Security	Required
P2	SQL Injection	Critical	Backend/Security	Required

Manual Validation Required

The following items represent candidates, unconfirmed observations, or weak signals where direct proof of exploitability was unavailable during automated testing. These findings must be reviewed and verified manually before setting remediation SLAs.

ID	Finding	Classification	Confidence	Why Validation is Required
VLN-AF3A	Cryptographic / Transport Wea...	Informational	0/10	-2 Finding is an observation-only signal (surface discove...

Methodology and Scope

Centrix performed dynamic application testing against the authorised target using discovery, crawl, passive analysis, active probes, evidence capture, and report aggregation.

Target	http://testaspnet.vulnweb.com/
Scope Patterns	Same-origin target scope
Safety Mode	standard
Max Requests	500
Robots Policy	Not enforced
Evidence Records	60

Compliance Reference

Standard	Relevant Controls
PCI DSS 4.0	6.2 secure development, 6.4 public-facing application protection
SOC 2	CC6.1 logical access, CC7.1 system monitoring
ISO 27001:2022	A.8.26 application security, A.8.28 secure coding
NIST 800-53	SA-11 developer testing, SI-10 input validation
GDPR	Article 32 security of processing

Potential Attack Scenarios

Scenario 1: SQL Injection

An attacker identifies the affected target (http://testaspnet.vulnweb.com/ReadNews.aspx) and attempts to exploit the weakness around id. Successful exploitation could affect confidentiality, integrity, or availability depending on business logic.

- Locate the affected URL and parameter from the finding evidence.
- Reproduce the observed behavior using a controlled test request.
- Assess whether authentication, authorization, or input validation changes the result.
- Apply remediation and retest the same path in Centrix.

Scenario 2: SQL Injection

An attacker identifies the affected target (http://testaspnet.vulnweb.com/Comments.aspx) and attempts to exploit the weakness around id. Successful exploitation could affect confidentiality, integrity, or availability depending on business logic.

- Locate the affected URL and parameter from the finding evidence.
- Reproduce the observed behavior using a controlled test request.
- Assess whether authentication, authorization, or input validation changes the result.
- Apply remediation and retest the same path in Centrix.

Scenario 3: Cryptographic / Transport Weakness (Surface Observation)

An attacker identifies the affected target (http://testaspnet.vulnweb.com/) and attempts to exploit the weakness around scheme. Successful exploitation could affect confidentiality, integrity, or availability depending on business logic.

- Locate the affected URL and parameter from the finding evidence.
- Reproduce the observed behavior using a controlled test request.
- Assess whether authentication, authorization, or input validation changes the result.
- Apply remediation and retest the same path in Centrix.

Table of Contents

1. Executive Summary
2. Remediation Plan
3. Methodology and Scope
4. Potential Attack Scenarios
5. Detailed Findings

5.1 SQL Injection
5.2 SQL Injection
5.3 Cryptographic / Transport Weakness (Surface Observation)

Detailed Findings

1. SQL Injection

CRITICAL

Severity	Critical
Classification	Confirmed
Confidence	8/10 (Confirmed)
CVSS	9.8
CWE	CWE-89
Category	Injection
Target	http://testaspnet.vulnweb.com/ReadNews.aspx
Parameter	id
Reproduction	reproduced
Validation Status	validated
Evidence Artifacts	1
Status	Open
Suggested Owner	Backend/Security
Retest Priority	Required

Description

Detected via active probe. Payload evaluated: `'`

Evidence

```
GET http://testaspnet.vulnweb.com/ReadNews.aspx HTTP/1.1
HTTP 200
Content-Type: unknown
Response-Length: 106


Single-quote injection broke backend query causing unhandled stream abort (0 bytes vs 13481
byte baseline)
```

Remediation

- Use parameterized queries or prepared statements for all database interactions
- Never concatenate user input into SQL strings
- Adopt an ORM with built-in protections

Retest Checklist

- Re-run the original request against /ReadNews.aspx after the fix is deployed.
- Confirm the vulnerable payload no longer changes response behavior or data access.
- Capture before/after evidence in Proof Mode and attach it to the finding.
- Keep the regression test in the owning service or API test suite.

References

https://owasp.org/
https://cwe.mitre.org/

2. SQL Injection

CRITICAL

Severity	Critical
Classification	Confirmed
Confidence	8/10 (Confirmed)
CVSS	9.8
CWE	CWE-89
Category	Injection
Target	http://testaspnet.vulnweb.com/Comments.aspx
Parameter	id
Reproduction	reproduced
Validation Status	validated
Evidence Artifacts	1
Status	Open
Suggested Owner	Backend/Security
Retest Priority	Required

Description

Detected via active probe. Payload evaluated: ``'``

Evidence

```
GET http://testaspnet.vulnweb.com/Comments.aspx HTTP/1.1
HTTP 200
Content-Type: unknown
Response-Length: 106


Single-quote injection broke backend query causing unhandled stream abort (0 bytes vs 14325
byte baseline)
```

Remediation

- Use parameterized queries or prepared statements for all database interactions
- Never concatenate user input into SQL strings
- Adopt an ORM with built-in protections

Retest Checklist

- Re-run the original request against /Comments.aspx after the fix is deployed.

- Confirm the vulnerable payload no longer changes response behavior or data access.
- Capture before/after evidence in Proof Mode and attach it to the finding.
- Keep the regression test in the owning service or API test suite.

References

https://owasp.org/
https://cwe.mitre.org/

3. Cryptographic / Transport Weakness (Surface Observation)

INFO

Severity	Info
Classification	Informational
Confidence	0/10 (Informational)
CVSS	N/A
CWE	CWE-319
Category	Cryptography
Target	http://testaspnet.vulnweb.com/
Parameter	scheme
Reproduction	untested
Validation Status	pending
Evidence Artifacts	1
Status	Open
Suggested Owner	Platform/SecOps
Retest Priority	Optional

Why this may be a false positive

False-Positive Risk Analysis: -2 Finding is an observation-only signal (surface discovery, header, banner).

Description

Detected via active probe. Payload evaluated: `N/A`

Evidence

```
GET http://testaspnet.vulnweb.com/ HTTP/1.1
HTTP 200
Content-Type: text/html; charset=utf-8
Response-Length: 1000
cache-control: private
content-length: 14045
content-type: text/html; charset=utf-8
date: Thu, 08 Oct 2026 19:49:03 GMT
server: Microsoft-IIS/8.5
set-cookie: ASP.NET_SessionId=2oqcp255s1nxqrb3s5exsm45; path=/; HttpOnly
x-aspnet-version: 2.0.50727
x-powered-by: ASP.NET

Site served over unencrypted HTTP. Traffic visible to network attackers.
```

Remediation

- Enforce HTTPS, secure cookies, modern TLS, HSTS, and avoid exposing sensitive values in responses

Retest Checklist

- Re-run the original request against / after the fix is deployed.
- Confirm the vulnerable payload no longer changes response behavior or data access.
- Capture before/after evidence in Proof Mode and attach it to the finding.
- Keep the regression test in the owning service or API test suite.

References

https://owasp.org/
https://cwe.mitre.org/

Disclaimer

This report is provided for security assessment and remediation planning. Automated DAST results can include false positives and false negatives. Validate high-impact findings manually before external disclosure or production changes.